

RELATÓRIO DE AUDITORIA E SEGURANÇA DE SISTEMAS



Formando:Odair Santos Mota

Formador: Valério Santos

Modulo:Linux e Segurança na Cloud

Data:09/06/2026

Índice

1. Identificação do Trabalho e Autoria.....	1
2. Caracterização do Serviço Analisado.....	1
3. Mapeamento da Superfície de Ataque.....	1
4. Desenho Técnico das Regras de Firewall.....	4
5. Plano de Hardening Inicial Implementado	5
6. Matriz do Plano de Validação Operacional	6
7. Rastreabilidade e Repositório GitHub	8
8. Conclusão Final.....	9

Plano de Segurança Inicial para Serviço Web Publicado – Tópico 04

1. Identificação do Trabalho e Autoria

- **Identificação do Grupo:** Trabalho Adaptado para Regime Individual
- **Autor / Formando:** Odair Santos Mota
- **Perfil Profissional / Papéis Assumidos:** Administrador de Sistemas Linux e Auditor de Conformidade de Infraestruturas de Dados.

2. Caracterização do Serviço Analisado

- **Cenário Selecionado:** Cenário C – Sistema de Gestão de Conteúdos (CMS) WordPress sobre Servidor Web Apache.
- **Portas e Protocolos Ativos:** Porta 80/TCP para tráfego web padrão não-cifrado (HTTP) e Porta 22/TCP para o protocolo de administração e gestão remota segura (SSH).
- **Diretório de Publicação no Sistema de Ficheiros:** /var/www/html/wordpress
- **Componentes Tecnológicos Envolvidos:** Servidor Web Apache2 (v2.4), Interpretador de Scripts PHP 8.x, e Sistema de Gestão de Base de Dados Relacional MariaDB / MySQL Server.
- **Dependências Críticas do Sistema:** Módulos nativos do Apache (mod_rewrite para links permanentes), extensões PHP essenciais (php-mysql para comunicação com o banco, php-xml e php-gd para processamento de media) e o utilitário de sistema ufw (Uncomplicated Firewall) para isolamento perimetral.

3. Mapeamento da Superfície de Ataque

A tabela seguinte descreve os elementos expostos na infraestrutura atual, os riscos associados e as contramedidas imediatas propostas:

Elemento Exposto	Risco Identificado	Estritamente Necessário?	Medida de Mitigação Proposta
Acesso SSH (Porta 22)	Ataques automatizados de força bruta e tentativas de intrusão por dicionário na porta padrão.	Sim (Para gestão remota)	Restringir o acesso a IPs fidedignos via firewall e implementar autenticação baseada em chaves criptográficas (mecanismo par de chaves pública/privada), desativando o login por senha tradicional.
Acesso HTTP (Porta 80)	Intercepção de credenciais administrativas e dados de utilizadores em trânsito (ataques de Sniffing) devido à ausência de criptografia.	Sim (Para acesso público)	Manter operacional temporariamente para validação de conectividade local, agendando a transição imediata para tráfego cifrado.
Acesso HTTPS (Porta 443)	Exploração de falhas em cifras criptográficas antigas ou	Não (Ainda não configurado)	Manter a porta fechada na firewall perimetral até que um certificado digital SSL/TLS

Elemento Exposto	Risco Identificado	Estritamente Necessário?	Medida de Mitigação Proposta
	certificados mal configurados.		válido (ex: Let's Encrypt) seja formalmente emitido e instalado no Apache.
Base de Dados MariaDB (Porta 3306)	Injeção de código SQL (SQLi), tentativas de conexão externa direta e exposição de tabelas com dados de utilizadores à rede.	Não (Apenas uso local)	Alterar a diretiva de escuta do serviço no ficheiro de configuração para o IP de loopback (127.0.0.1) e bloquear nativamente qualquer tráfego externo nesta porta através do firewall.
Diretório Web Geral	Listagem pública de ficheiros (<i>Directory Browsing</i>), permitindo a atacantes mapear a árvore estrutural da aplicação e identificar ficheiros órfãos.	Sim (Para o CMS)	Injetar a diretiva Options -Indexes nos ficheiros de configuração do Apache para proibir a listagem visual e remover scripts informativos remanescentes (ex: info.php).

Elemento Exposto	Risco Identificado	Estritamente Necessário?	Medida de Mitigação Proposta
Painel de Administração (/wp-admin)	Ataques persistentes de força bruta direcionados ao ficheiro wp-login.php para sequestro de contas administrativas.	Sim (Para edição do site)	Impor o uso de credenciais de alta complexidade e implementar módulos de segurança ao nível da aplicação para limitação de tentativas consecutivas de login por IP.

4. Desenho Técnico das Regras de Firewall

Com base no princípio fundamental da segurança da informação do "Menor Privilégio" (onde todo o tráfego é proibido até que se prove o contrário), foi desenhada e implementada a seguinte matriz de filtragem de pacotes com o utilitário UFW:

Serviço Alvo	Porto / Protocolo	Decisão Aplicada	Justificação Técnica e Operacional
SSH	22 / TCP	PERMITIR	Garante a continuidade do canal de comunicação e administração remota segura do Engenheiro de Sistemas à Máquina Virtual Ubuntu.
HTTP	80 / TCP	PERMITIR	Autoriza a entrada de tráfego legítimo vindo dos navegadores

Serviço Alvo	Porto / Protocolo	Decisão Aplicada	Justificação Técnica e Operacional
			da rede local para visualização do ecossistema WordPress e páginas web estáticas.
HTTPS	443 / TCP	BLOQUEAR	Aplica a política defensiva de fechar portas que não possuem um serviço seguro (TLS/SSL) em plena execução no servidor.
MariaDB / MySQL	3306 / TCP	BLOQUEAR	Elimina por completo o vetor de ataque externo direto à base de dados. A comunicação entre o Apache e o MariaDB é feita estritamente de forma interna (localhost).

5. Plano de Hardening Inicial Implementado

Foram selecionadas e executadas seis ações coordenadas na máquina virtual para estabelecer uma linha base de segurança (*baseline*) robusta:

1. **Saneamento e Atualização do Sistema Operativo:** Execução do comando `sudo apt update && sudo apt upgrade -y` para garantir a correção de vulnerabilidades conhecidas nos pacotes estruturais do Linux.
2. **Isolamento de Redundância da Base de Dados:** Configuração explícita do parâmetro `bind-address = 127.0.0.1` no ficheiro `/etc/mysql/mariadb.conf.d/50-server.cnf`, eliminando escutas na interface genérica (0.0.0.0).

3. **Saneamento do Diretório de Produção:** Remoção ou transferência preventiva de ficheiros de documentação padrão que expõem a estrutura interna do CMS, tais como o wp-config-sample.php original da pasta pública do Apache.
4. **Ocultação de Metadados e Versões (Banner Grabbing):** Planeamento das diretivas ServerTokens Prod e ServerSignature Off no Apache para impedir que o servidor divulgue a sua versão exata e o SO em cabeçalhos HTTP de erro.
5. **Restrição de Privilégios no Sistema:** Configuração do ambiente para impedir o uso direto do utilizador root em tarefas de manutenção quotidiana da aplicação, forçando o uso de perfis específicos com privilégios mitigados via sudo.
6. **Políticas de Autenticação Forte:** Aplicação rigorosa de senhas complexas e de alta entropia (combinando letras maiúsculas, minúsculas, números e caracteres especiais) tanto no utilizador administrador do WordPress quanto nas credenciais de ligação interna do banco de dados.

6. Matriz do Plano de Validação Operacional

Para auditar e validar a eficácia real das barreiras de segurança levantadas, foi estruturado o seguinte plano de testes:

Elemento de Validação	Método de Execução do Teste	Resultado Esperado pós-Hardening	Tipo de Evidência Associada
Estado Ativo da Firewall	Execução do comando de sistema: sudo ufw status verbose no terminal SSH.	O estado deve reportar active com a política padrão deny (incoming) e as portas 22 e 80	Captura de ecrã (Print) do terminal Linux demonstrando o output

Elemento de Validação	Método de Execução do Teste	Resultado Esperado pós-Hardening	Tipo de Evidência Associada
		explicitamente liberadas.	correto do utilitário.
Acessibilidade do Serviço Web	Submissão do URL http://192.168.1.110/wordpress num navegador web na máquina anfitriã (Windows).	Carregamento imediato e correto da página de configuração ou conteúdo do WordPress.	Print do ecrã do browser mostrando o site acessível e o IP na barra de endereços.
Persistência da Gestão SSH	Abertura de uma nova sessão de terminal remoto através da PowerShell do Windows.	Conexão estabelecida com sucesso e sem interrupções na sessão atual, validando a regra da porta 22.	Print da consola PowerShell com a sessão SSH ativa e operacional.
Bloqueio Perimetral de Portas	Execução de teste de varrimento local ou tentativa de conexão externa direcionada à porta 3306.	A tentativa de conexão externa deve falhar por	Registo de auditoria interna ou ausência de

Elemento de Validação	Método de Execução do Teste	Resultado Esperado pós-Hardening	Tipo de Evidência Associada
		<i>timeout</i> ou ser rejeitada silenciosamente pelo firewall perimetral.	resposta externa ao porto bloqueado.

7. Rastreabilidade e Repositório GitHub

Todos os ficheiros fontes, registos de comandos utilizados e evidências gráficas que sustentam os resultados deste relatório estão catalogados e disponíveis publicamente para auditoria técnica no seguinte repositório:

- **Link Direto:** <https://github.com/odairmota/Linux-Seguranca-Cloud>

8. Conclusão Final

A execução deste Plano de Segurança Inicial demonstra que a proteção eficiente de uma infraestrutura baseada na stack LAMP (Apache, MariaDB, WordPress) não exige de imediato configurações de extrema complexidade, mas sim a aplicação rigorosa de uma política de redução da superfície de ataque ao nível de rede e sistema.

Ao confinar o tráfego de dados apenas aos portos estritamente operacionais (SSH e HTTP) e ao isolar o motor de base de dados para comunicação puramente local, neutralizam-se os vetores automatizados de intrusão mais comuns na internet. Este esforço garante a conformidade operacional da infraestrutura, salvaguarda a integridade dos dados da aplicação e cria uma base sólida e resiliente para as implementações avançadas de segurança que serão executadas no próximo tópico de infraestrutura cloud.